



Hands on Hacking

Matthew Hickey
with
Jennifer Arcuri

WILEY

Copyright © 2020 by John Wiley & Sons, Inc., Indianapolis, Indiana

Published simultaneously in Canada and the United Kingdom

ISBN: 978-1-119-56145-3

ISBN: 978-1-119-56148-4 (ebk)

ISBN: 978-1-119-56151-4 (ebk)

Manufactured in the United States of America

No part of this publication may be reproduced, stored in a retrieval system or transmitted in any form or by any means, electronic, mechanical, photocopying, recording, scanning or otherwise, except as permitted under Sections 107 or 108 of the 1976 United States Copyright Act, without either the prior written permission of the Publisher, or authorization through payment of the appropriate per-copy fee to the Copyright Clearance Center, 222 Rosewood Drive, Danvers, MA 01923, (978) 750-8400, fax (978) 646-8600. Requests to the Publisher for permission should be addressed to the Permissions Department, John Wiley & Sons, Inc., 111 River Street, Hoboken, NJ 07030, (201) 748-6011, fax (201) 748-6008, or online at www.wiley.com/go/permissions.

Limit of Liability/Disclaimer of Warranty: The publisher and the author make no representations or warranties with respect to the accuracy or completeness of the contents of this work and specifically disclaim all warranties, including without limitation warranties of fitness for a particular purpose. No warranty may be created or extended by sales or promotional materials. The advice and strategies contained herein may not be suitable for every situation. This work is sold with the understanding that the publisher is not engaged in rendering legal, accounting, or other professional services. If professional assistance is required, the services of a competent professional person should be sought. Neither the publisher nor the author shall be liable for damages arising herefrom. The fact that an organization or Web site is referred to in this work as a citation and/or a potential source of further information does not mean that the author or the publisher endorses the information the organization or website may provide or recommendations it may make. Further, readers should be aware that Internet websites listed in this work may have changed or disappeared between when this work was written and when it is read.

For general information on our other products and services please contact our Customer Care Department within the United States at (877) 762-2974, outside the United States at (317) 572-3993 or fax (317) 572-4002.

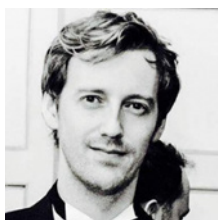
Wiley publishes in a variety of print and electronic formats and by print-on-demand. Some material included with standard print versions of this book may not be included in e-books or in print-on-demand. If this book refers to media such as a CD or DVD that is not included in the version you purchased, you may download this material at booksupport.wiley.com. For more information about Wiley products, visit www.wiley.com.

Library of Congress Control Number: 2020937933

Trademarks: Wiley and the Wiley logo are trademarks or registered trademarks of John Wiley & Sons, Inc. and/or its affiliates, in the United States and other countries, and may not be used without written permission. All other trademarks are the property of their respective owners. John Wiley & Sons, Inc. is not associated with any product or vendor mentioned in this book.

This book is dedicated to all those who seek knowledge and understanding of computer hacking. It is our hope that this book helps guide you, future and present hackers, in achieving your goals and aspirations.

About the Authors



Matthew Hickey is a professional hacker with more than 20 years of experience and the cofounder of cybersecurity company Hacker House. He has obtained a variety of CESS CHECK and CREST certifications during his career and awarded a fellowship by CREST for his technical skills. He has been frequently sought to lead long-term assessments that accurately reflect real-world security challenges, simulating attacks on global businesses and high-risk environments. Predominantly, he specializes in offensive security testing, highlighting vulnerabilities leveraged by malicious attacker's so that appropriate remediation can be sought and implemented. He develops bespoke exploits and security tools for use in cybersecurity testing engagements.

Matthew spends most of his time hacking computers, conducting penetration tests, creating training material, writing exploits, and developing hacking tools. During 2019, he published instructions for hacking U.S. electronic voting machines to play the video game classic DooM as well as details of surveillance software used in North Korean smartphones. He has presented at security conferences on his research into security of embedded systems, cryptography, software exploitation, mobility solutions, and wireless technologies.

Matthew has an online following from his work and regularly comments in the press on cybersecurity topics such as when critical flaws are found in operating systems, attacks involving cryptocurrency, North Korean cybersecurity, the NSA's leaked hacking tools, and security of the UK's National Health Service. He has developed and published zero-day exploits and security testing tools against product vendors including Microsoft, Apple, NetBSD, Cisco, Linux, Hewlett Packard, SCO, Sun Microsystems, Silicon Graphics, IBM, SAGEM, OpenBSD, and NetGear to name just a few. Matthew is from Manchester, England, a city famous for its football teams, art, musicians, and hackers.



Jennifer Arcuri is a serial entrepreneur who now focuses on improving cybersecurity awareness and training in the UK and USA. She is the founder and CEO of Hacker House, a UK-based security company. In 2012, Jennifer founded one of London's leading tech conferences, the InnoTech Summit, a high-profile event series that brought together key policymakers, corporations, and startups to

bridge the gap between legislation and innovative technology. In 2014–2015, the InnoTech Network specialized in a series of events around information security and the need for cyber skills. It brought together law enforcement and influential leaders from the Prime Minister's office, Department of Culture and Media, Metropolitan Police for the City of London, Ministry of Defence, and the National Crimes Agency. Her events, as well as the community movement formed with a team of hackers in a house, led to one of the strongest ethical hacking campaigns in the United Kingdom for the endorsement of educating and teaching ethical hacking skills. Her work became most popular during her TEDx Talk in Liverpool, "Why Ethical Hacking Is Important in a 21st Century," which helped encourage policy change in the United Kingdom around education and cyber skills advocacy in classrooms. Jennifer was also an integral part of various skills campaigns across the United Kingdom, including speaking to classrooms across London surrounding the issues of cyber bullying, what to do in case of a security breach, and children's safety online. Through her efforts in legislation, events, and security, Jennifer started Hacker House as a community of hackers in east London in 2014, and since then has launched an online training portal to help educate more people into the cybersecurity industry. Over the past few years, Hacker House has trained students all over the world and has expanded their work to help further encourage companies to adopt the same strategy of utilizing cyber skills.



About the Technical Editors

Kevin Cardwell spent 22 years in the U.S. Navy. He has worked as both a software and systems engineer on a variety of Department of Defense projects. Early on, he was chosen as a member of the project designed to bring Internet access to ships at sea. Following completion of this highly successful project, Kevin was selected to head the team that built a network operations and security center (NOSC) that provided services to the commands ashore and ships at sea in the Norwegian Sea and Atlantic Ocean. Kevin served as the leading chief of information security at the NOSC for six years. While there, he created a strategy and training plan for the development of an expert team that took personnel with little or no experience and built them into expert team members for manning the NOSC.

Kevin currently is president of two cybersecurity consulting companies. He holds a BS in computer science from National University in California and a MS in software engineering from the Southern Methodist University (SMU) in Texas.

Megan Daudelin works as a consultant in the cybersecurity field. She holds a bachelor's degree and a master's degree as well as industry certifications. Throughout her career, Megan has worked as a digital forensic analyst, information security analyst, cyber range developer, and cybersecurity curriculum designer. On the side, Megan enjoys contributing to the publication of books and teaching at her alma mater. Outside of the industry, Megan fills her time exploring New England with her spouse and their two German Shepherds.



Acknowledgments

The authors would like to thank the editing team at Wiley, notably Gary Schwartz, Kevin Cardwell, and Megan Daudelin, for their feedback, ideas, and technical input throughout this project, making this book far greater than it would have been without them! Our thanks also go to everyone else at Wiley, especially Barath Kumar Rajasekaran, for their continued patience and understanding throughout; there have been a few bumps in the road, and you have stuck with us. Finally, Hacker House would like to thank Elisa Tidswell and Edward Archer for all of their help at the company while this book was created.



Contents at a Glance

Foreword	xviii
Introduction	xx
Chapter 1 Hacking a Business Case	1
Chapter 2 Hacking Ethically and Legally	13
Chapter 3 Building Your Hack Box	23
Chapter 4 Open Source Intelligence Gathering	55
Chapter 5 The Domain Name System	87
Chapter 6 Electronic Mail	135
Chapter 7 The World Wide Web of Vulnerabilities	191
Chapter 8 Virtual Private Networks	251
Chapter 9 Files and File Sharing	283
Chapter 10 UNIX	315
Chapter 11 Databases	355
Chapter 12 Web Applications	395
Chapter 13 Microsoft Windows	457
Chapter 14 Passwords	517
Chapter 15 Writing Reports	543
Index	561



Contents

Foreword	xviii
Introduction	xx
Chapter 1 Hacking a Business Case	1
All Computers Are Broken	2
The Stakes	4
What's Stolen and Why It's Valuable	4
The Internet of Vulnerable Things	4
Blue, Red, and Purple Teams	5
Blue Teams	5
Red Teams	5
Purple Teams	7
Hacking is Part of Your Company's Immune System	9
Summary	11
Notes	12
Chapter 2 Hacking Ethically and Legally	13
Laws That Affect Your Work	14
Criminal Hacking	15
Hacking Neighborly	15
Legally Gray	16
Penetration Testing Methodologies	17
Authorization	18
Responsible Disclosure	19
Bug Bounty Programs	20
Legal Advice and Support	21
Hacker House Code of Conduct	22
Summary	22

Chapter 3	Building Your Hack Box	23
	Hardware for Hacking	24
	Linux or BSD?	26
	Host Operating Systems	27
	Gentoo Linux	27
	Arch Linux	28
	Debian	28
	Ubuntu	28
	Kali Linux	29
	Verifying Downloads	29
	Disk Encryption	31
	Essential Software	33
	Firewall	34
	Password Manager	35
	Email	36
	Setting Up VirtualBox	36
	Virtualization Settings	37
	Downloading and Installing VirtualBox	37
	Host-Only Networking	37
	Creating a Kali Linux VM	40
	Creating a Virtual Hard Disk	42
	Inserting a Virtual CD	43
	Virtual Network Adapters	44
	Labs	48
	Guest Additions	51
	Testing Your Virtual Environment	52
	Creating Vulnerable Servers	53
	Summary	54
Chapter 4	Open Source Intelligence Gathering	55
	Does Your Client Need an OSINT Review?	56
	What Are You Looking For?	57
	Where Do You Find It?	58
	OSINT Tools	59
	Grabbing Email Addresses from Google	59
	Google Dorking the Shadows	62
	A Brief Introduction to Passwd and Shadow Files	62
	The Google Hacking Database	65
	Have You Been “Pwned” Yet?	66
	OSINT Framework Recon-ng	67
	Recon-ng Under the Hood	74
	Harvesting the Web	75
	Document Metadata	76
	Maltego	80
	Social Media Networks	81
	Shodan	83
	Protecting Against OSINT	85
	Summary	86

Chapter 5	The Domain Name System	87
	The Implications of Hacking DNS	87
	A Brief History of DNS	88
	The DNS Hierarchy	88
	A Basic DNS Query	89
	Authority and Zones	92
	DNS Resource Records	92
	BIND9	95
	DNS Hacking Toolkit	98
	Finding Hosts	98
	WHOIS	98
	Brute-Forcing Hosts with Recon-ng	100
	Host	101
	Finding the SOA with Dig	102
	Hacking a Virtual Name Server	103
	Port Scanning with Nmap	104
	Digging for Information	106
	Specifying Resource Records	108
	Information Leak CHAOS	111
	Zone Transfer Requests	113
	Information-Gathering Tools	114
	Fierce	115
	Dnsrecon	116
	Dnsenum	116
	Searching for Vulnerabilities and Exploits	118
	Searchsploit	118
	Other Sources	119
	DNS Traffic Amplification	120
	Metasploit	121
	Carrying Out a Denial-of-Service Attack	125
	DoS Attacks with Metasploit	126
	DNS Spoofing	128
	DNS Cache Poisoning	129
	DNS Cache Snooping	131
	DNSSEC	131
	Fuzzing	132
	Summary	134
Chapter 6	Electronic Mail	135
	The Email Chain	135
	Message Headers	137
	Delivery Status Notifications	138
	The Simple Mail Transfer Protocol	141
	Sender Policy Framework	143
	Scanning a Mail Server	145
	Complete Nmap Scan Results (TCP)	149
	Probing the SMTP Service	152

Open Relays	153
The Post Office Protocol	155
The Internet Message Access Protocol	157
Mail Software	158
Exim	159
Sendmail	159
Cyrus	160
PHP Mail	160
Webmail	161
User Enumeration via Finger	162
Brute-Forcing the Post Office	167
The Nmap Scripting Engine	169
CVE-2014-0160: The Heartbleed Bug	172
Exploiting CVE-2010-4345	180
Got Root?	183
Upgrading Your Shell	184
Exploiting CVE-2017-7692	185
Summary	188
Chapter 7 The World Wide Web of Vulnerabilities	191
The World Wide Web	192
The Hypertext Transfer Protocol	193
HTTP Methods and Verbs	195
HTTP Response Codes	196
Stateless	198
Cookies	198
Uniform Resource Identifiers	200
LAMP: Linux, Apache, MySQL, and PHP	201
Web Server: Apache	202
Database: MySQL	203
Server-Side Scripting: PHP	203
Nginx	205
Microsoft IIS	205
Creepy Crawlers and Spiders	206
The Web Server Hacker's Toolkit	206
Port Scanning a Web Server	207
Manual HTTP Requests	210
Web Vulnerability Scanning	212
Guessing Hidden Web Content	216
Nmap	217
Directory Busting	218
Directory Traversal Vulnerabilities	219
Uploading Files	220
WebDAV	220
Web Shell with Weevely	222
HTTP Authentication	223
Common Gateway Interface	225

Shellshock	226
Exploiting Shellshock Using Metasploit	227
Exploiting Shellshock with cURL and Netcat	228
SSL, TLS, and Heartbleed	232
Web Administration Interfaces	238
Apache Tomcat	238
Webmin	240
phpMyAdmin	241
Web Proxies	242
Proxychains	243
Privilege Escalation	245
Privilege Escalation Using DirtyCOW	246
Summary	249
Chapter 8 Virtual Private Networks	251
What Is a VPN?	251
Internet Protocol Security	253
Internet Key Exchange	253
Transport Layer Security and VPNs	254
User Databases and Authentication	255
SQL Database	255
RADIUS	255
LDAP	256
PAM	256
TACACS+	256
The NSA and VPNs	257
The VPN Hacker's Toolkit	257
VPN Hacking Methodology	257
Port Scanning a VPN Server	258
Hping3	259
UDP Scanning with Nmap	261
IKE-scan	262
Identifying Security Association Options	263
Aggressive Mode	265
OpenVPN	267
LDAP	275
OpenVPN and Shellshock	277
Exploiting CVE-2017-5618	278
Summary	281
Chapter 9 Files and File Sharing	283
What Is Network-Attached Storage?	284
File Permissions	284
NAS Hacking Toolkit	287
Port Scanning a File Server	288
The File Transfer Protocol	289

	The Trivial File Transfer Protocol	291
	Remote Procedure Calls	292
	RPCinfo	294
	Server Message Block	295
	NetBIOS and NBT	296
	Samba Setup	298
	Enum4Linux	299
	SambaCry (CVE-2017-7494)	303
	Rsync	306
	Network File System	308
	NFS Privilege Escalation	309
	Searching for Useful Files	311
	Summary	312
Chapter 10	UNIX	315
	UNIX System Administration	316
	Solaris	316
	UNIX Hacking Toolbox	318
	Port Scanning Solaris	319
	Telnet	320
	Secure Shell	324
	RPC	326
	CVE-2010-4435	329
	CVE-1999-0209	329
	CVE-2017-3623	330
	Hacker's Holy Grail EBBSHAVE	331
	EBBSHAVE Version 4	332
	EBBSHAVE Version 5	335
	Debugging EBBSHAVE	335
	R-services	338
	The Simple Network Management Protocol	339
	Ewok	341
	The Common UNIX Printing System	341
	The X Window System	343
	Cron and Local Files	347
	The Common Desktop Environment	351
	EXTREMEFARR	351
	Summary	353
Chapter 11	Databases	355
	Types of Databases	356
	Flat-File Databases	356
	Relational Databases	356
	Nonrelational Databases	358
	Structured Query Language	358
	User-Defined Functions	359
	The Database Hacker's Toolbox	360
	Common Database Exploitation	360

Port Scanning a Database Server	361
MySQL	362
Exploring a MySQL Database	362
MySQL Authentication	373
PostgreSQL	374
Escaping Database Software	377
Oracle Database	378
MongoDB	381
Redis	381
Privilege Escalation via Databases	384
Summary	392
Chapter 12 Web Applications	395
The OWASP Top 10	396
The Web Application Hacker's Toolkit	397
Port Scanning a Web Application Server	397
Using an Intercepting Proxy	398
Setting Up Burp Suite Community Edition	399
Using Burp Suite Over HTTPS	407
Manual Browsing and Mapping	412
Spidering	415
Identifying Entry Points	418
Web Vulnerability Scanners	418
Zed Attack Proxy	419
Burp Suite Professional	420
Skipfish	421
Finding Vulnerabilities	421
Injection	421
SQL Injection	422
SQLmap	427
Drupageddon	433
Protecting Against SQL Injection	433
Other Injection Flaws	434
Broken Authentication	434
Sensitive Data Exposure	436
XML External Entities	437
CVE-2014-3660	437
Broken Access Controls	439
Directory Traversal	440
Security Misconfiguration	441
Error Pages and Stack Traces	442
Cross-Site Scripting	442
The Browser Exploitation Framework	445
More about XSS Flaws	450
XSS Filter Evasion	450
Insecure Deserialization	452
Known Vulnerabilities	453
Insufficient Logging and Monitoring	453

Privilege Escalation	454
Summary	455
Chapter 13 Microsoft Windows	457
Hacking Windows vs. Linux	458
Domains, Trees, and Forests	458
Users, Groups, and Permissions	461
Password Hashes	461
Antivirus Software	462
Bypassing User Account Control	463
Setting Up a Windows VM	464
A Windows Hacking Toolkit	466
Windows and the NSA	467
Port Scanning Windows Server	467
Microsoft DNS	469
Internet Information Services	470
Kerberos	471
Golden Tickets	472
NetBIOS	473
LDAP	474
Server Message Block	474
ETERNALBLUE	476
Enumerating Users	479
Microsoft RPC	489
Task Scheduler	497
Remote Desktop	497
The Windows Shell	498
PowerShell	501
Privilege Escalation with PowerShell	502
PowerSploit and AMSI	503
Meterpreter	504
Hash Dumping	505
Passing the Hash	506
Privilege Escalation	507
Getting SYSTEM	508
Alternative Payload Delivery Methods	509
Bypassing Windows Defender	512
Summary	514
Chapter 14 Passwords	517
Hashing	517
The Password Cracker's Toolbox	519
Cracking	519
Hash Tables and Rainbow Tables	523
Adding Salt	525
Into the <i>/etc/shadow</i>	526
Different Hash Types	530

MD5	530
SHA-1	531
SHA-2	531
SHA256	531
SHA512	531
bcrypt	531
CRC16/CRC32	532
PBKDF2	532
Collisions	533
Pseudo-hashing	533
Microsoft Hashes	535
Guessing Passwords	537
The Art of Cracking	538
Random Number Generators	539
Summary	540
Chapter 15 Writing Reports	543
What Is a Penetration Test Report?	544
Common Vulnerabilities Scoring System	545
Attack Vector	545
Attack Complexity	546
Privileges Required	546
User Interaction	547
Scope	547
Confidentiality, Integrity, and Availability Impact	547
Report Writing as a Skill	549
What Should a Report Include?	549
Executive Summary	550
Technical Summary	551
Assessment Results	551
Supporting Information	552
Taking Notes	553
Dradis Community Edition	553
Proofreading	557
Delivery	558
Summary	559
Index	561



Foreword

This foreword was written by Rey Bango, who is a security advocate at Microsoft focused on helping the community build secure systems and being a voice for the security practitioners within Microsoft. Rey transitioned to cybersecurity after nearly 30 years as a software developer.

I never envisioned becoming a cybersecurity professional. I had been a software developer for so long that the thought of shifting careers hadn't really crossed my mind. I think that I was similar to other developers in that security was an IT problem—not a software problem—so why should I worry about it? Boy, was I ever wrong.

The reality is that the efforts of bad actors continue to evolve as they attempt to bypass the defenses that companies put up. As companies push toward cloud-native managed solutions, focusing on infrastructure attacks has become more costly and time-consuming. In the world of cybercrime, time is money. So, finding easier entry points is a much wiser investment for many cybercriminals.

This is where web services come in. Developers are bound to make mistakes (we're human, after all) as they build systems, whether it's poorly sanitized input or accidentally leaving an API key exposed in a public git repo. These mistakes can be costly, and it's what got me to look into the security field.

I always envisioned bad actors who focused on the infrastructure side, poking holes in operating systems and system services to gain network access or using misconfigurations to glean valuable information. More and more, though, articles started appearing about how these same bad actors were leveraging poorly designed applications and software frameworks to compromise systems—even gaining full network access! This both scared me and piqued my interest. I wanted to learn more.

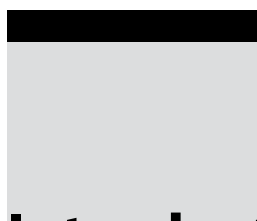
The Internet holds a wealth of information on how to “hack something,” but trying to piece together all of this information into something digestible for someone new to security can be a daunting task. The glut of information can easily overwhelm beginners and make them question whether cybersecurity is the right choice for them. This happened to me. I was quickly overwhelmed by the volume of security blog posts, videos, and tools that were great in and of themselves but that didn’t offer a cohesive layout as to where they fit into the security picture. I wanted a structured way of learning the techniques used by security professionals to test their systems. That’s where Hacker House came in.

Hacker House provided a curriculum that allowed me to develop the foundational skills necessary to understand how bad actors work. They answered not only “how” certain attacks are launched but also “why” specific techniques and tools are used in different scenarios.

The first time I popped a shell in class, I got that “aha!” moment that I sorely needed to grok how someone could remotely control another system. It allowed me to see how easily a network could be taken over by not properly sanitizing an upload and allowing a webshell to be installed. This was the reality check that I needed as a developer to understand that security touches *everything*.

I’ve since moved into a cybersecurity role at Microsoft, and one of the things that I’ve learned is that the cybersecurity field is a never-ending learning opportunity with many disciplines to dive into. You’ll always be challenged because bad actors will continue to push the boundaries. However, breaking into it will be the biggest challenge you face. I urge you to take the time to find a course that will set you up for success and a mentor who will take an interest in your career. I was fortunate to have Hacker House to guide me down my path.

—Rey Bango



Introduction

Welcome to our book on hacking. We believe there aren't too many books quite like this one. Yes, there are countless books out there about hacking (and information security, penetration testing, and so forth), but how many of those books give you everything that you need to start hacking your first computer systems, in a safe way, right from the get-go? Three labs are provided with this book—hacking sandboxes if you will—that you can run on your existing laptop or desktop computer. By using these labs, you will be able to try out various tools and techniques—*the same ones as those used by malicious hackers today*—without risk either to yourself or to the outside world. We will show you exactly how to hack these systems using open source tools that can be downloaded for free. You do not need to purchase anything else to try all of the practical exercises that we have included.

This book comes to you from the people behind Hacker House, a company specializing in online cybersecurity training and penetration testing services. Since its humble beginnings in east London in 2014, one of the reoccurring themes of Hacker House gatherings (we used to do a lot of meetups and events) has been how to properly identify talent and endorse cyber skills. We wanted to understand how we could capture the rebellious spirit of hacking—the one that causes hackers to question authority and the ways in which systems work. It was Jennifer Arcuri who first set about creating a company that could harness the potential of computer hacking and make it a usable asset for companies looking to bolster security, later joined by co-founder Matthew Hickey, who created content and technical resources to facilitate the Hacker House mission.

It's a rare day where there isn't some big "hack" that costs a company millions of dollars in losses or where identities are stolen or some other data theft takes place. One of the biggest reasons why companies are failing at security is because

they don't have the right cyber skills on their IT teams. Even if they hire an outside consultant, there is still no guarantee that the missing patches and security flaws that have been pointed out have now been resolved and that the company's data is indeed secure and protected from further attack.

We wrote this book with a vision toward a better way of developing cyber skills. Training consultants to become well versed in theory hasn't actually helped the landscape of attacks—we are still thousands of jobs short for what is an industry that is growing faster than we can keep up with it.

The content of this book started life as a training course, comprising 12 modules taught over 4 days in a classroom environment. That course can now be accessed online by anyone with an Internet connection from anywhere in the world. This book takes the hacking techniques and tools covered in that course and presents them as a written guide, with an emphasis on practical skills—that is, actually trying things out. We have taken the numerous labs used in our course and given you everything that you need in three labs. The same tools used by students in the course are also available to you. Unlike the training course, however, this book assumes less prior knowledge and gives you a deeper insight into the background theory of each technology that we hack. Instead of 12 modules, there are 15 chapters that closely follow the format of our tried-and-tested training course, but with additional content, including a chapter dedicated to report writing, a chapter for executives, and a chapter explaining how to configure your own computer system for the purpose of hacking.

The concepts taught in this book explain the mindset used by adversaries, the tools used, and the steps taken when attempting to breach a company and steal data. This knowledge could be seen as dual use: improving better defenders with the skills needed to stop adversaries yet also teaching the skills used by malicious adversaries. We won't teach you how not to get caught, but everything in this book has been designed to showcase how attackers target networks and access information. Many of the attacks demonstrated are based on real systems that our team has breached and encompass a broad spectrum of information security problems.

Our hope is that after learning about a different way of approaching computer security, you will contribute to the next generation of solutions within industry. We seek not only to teach and train you to be ready for employment but also to instill techniques that will shape the way that new tools and exploits are used to protect companies' digital assets.

Information security is an industry with many fun and exciting opportunities, and we encourage all those who want to try something that is relevant to our society to explore this book. Whatever your job in technology, isn't it time you learned how to protect yourself against modern cyber threats?

Who Should Read This Book

The book is aimed not only at those seeking an introduction to the world of ethical hacking and penetration testing, but for every single network or system administrator and Chief Information Security Officer (CISO) out there who is *ready to take security seriously*. We believe that to comprehend fully how a company will be targeted and breached, one must think and act like the assailant. Some readers will be happy reading through this book and gaining unique insight into the mind of an adversary. For those who want to take it further, there are practical exercises throughout. Those who fully master the content will have learned the skills required to conduct penetration tests, either within the company for which they work or for external clients, and find critical security flaws.

Hands on Hacking is essential reading for anyone who has recently taken on information security responsibilities in their workplace. Readers may not yet have started their career in IT, but this book will give them a thorough understanding of issues that affect any computer user. Readers will need a healthy interest in computing to get the most from the content, but little practical experience is actually required. We will delve into the various technologies—the protocols that make up the Internet, the World Wide Web, and internal networks—before looking at how to hack them.

We focus on Linux in this book, but even if you have little knowledge or experience with this operating system, we'll hold your hand throughout, and soon you'll become competent with the Linux command-line interface. We will even show you how to install Linux on your current computer without affecting your existing operating system—whether that be Windows or macOS.

What You Will Learn

You will learn how to approach a target organization from the point of view of a penetration tester or ethical hacker using the same skills and techniques that a malicious hacker would use. Your journey will begin in the realm of open source intelligence gathering, moving on to the external network infrastructure of a typical organization. We'll look for flaws and weaknesses and eventually break into the company's internal network through a Virtual Private Network (VPN) server, explaining everything as we go. Those who don't necessarily want to carry out the attacks themselves will witness exactly how information is gathered about their company and how attackers probe for holes and weaknesses before hacking in.

Once we've exposed the internal infrastructure, we'll find machines running Linux, UNIX, and Windows—each with their own flaws.

Using a range of tools, we'll exploit various vulnerabilities. We will also look at how those tools work and what they're doing under the hood so that readers can understand how to exploit vulnerabilities manually.

We'll gain access to a number of different computer systems and ultimately obtain Administrator permissions, allowing us to take over compromised systems completely. Along the way, we'll be collecting loot from the servers we visit. Among these will be a number of hashed passwords, which you'll learn how to crack towards the last chapter!

Finally, we'll show readers how they can formalize the entire process covered by writing reports of their findings that are suitable for company executives, clients, or colleagues—regardless of their technical understanding—and how an engagement with an external client is structured.

Readers will be able to practice many of the skills they come across using labs—sandbox environments designed for safe, legal hacking. These labs are made freely available to those purchasing the book. For those who want to understand what an attacker can do to their company, exploits are described in a way that makes sense and will help you realize the damage a missing patch can cause.

How This Book Is Organized

The book begins with a chapter that addresses the needs and concerns of company executives, followed by an important look at the legal and ethical aspects of computer hacking. Chapter 3, "Building Your Hack Box," is the first practical chapter. In it, we show you how to set your computer up for carrying out the activities in the rest of the book. Chapter 4, "Open Source Intelligence Gathering," details the passive, intelligence-gathering process undertaken before actively hacking into an organization's network. Chapters 5–13 address specific areas of a typical organization's infrastructure and introduce new tools and techniques as they are required. Chapter 14, "Passwords," focuses solely on the storage of passwords and how to retrieve them, with Chapter 15, "Writing Reports," the final chapter, looking at how to write up the results of your hacking so that problems can be fixed.

Chapter 1: Hacking a Business Case Translating computer security problems to businesses and understanding their mission objectives is a crucial element of how to use hacking effectively. This chapter is all about board rooms, risk, and understanding how to communicate information from the trenches of the computer networks back to those responsible for business decisions.

Chapter 2: Hacking Ethically and Legally We provide a brief introduction to the legal and ethical aspects of hacking. Not every hacker is a

criminal—quite the contrary. We'll provide some pointers on staying on the right side of the law and how to conduct your hacking professionally.

Chapter 3: Building Your Hack Box It's time to get practical. In this chapter, you will learn how to set up your own computer system step-by-step so that it is ready to start hacking, without hindering you from using it for your everyday work and leisure activities. We'll also show you how to set up your first lab in a virtual machine (VM) so that you have a target that can safely be explored and exploited.

Chapter 4: Open Source Intelligence Gathering Before you start hacking computer systems, you will learn how to gather information passively about your target. We use real-world examples in this chapter, as we are searching for and using publicly available information, but perhaps differently than what you've witnessed before.

Chapter 5: The Domain Name System The Domain Name System (DNS) is something on which we all rely, and yet many of us have little insight into how it works. In this chapter, you'll learn exactly what DNS is and how organizations, as well as individuals, rely on it. Then you'll learn some practical techniques for gathering information and searching for vulnerabilities before eventually exploiting them. We'll introduce some important tools in this chapter, including Nmap and Metasploit, which is crucial reading for understanding the rest of the book.

Chapter 6: Electronic Mail Through this chapter, you'll understand how email servers work and how to hack them. This chapter covers e-mail protocol basics, mail relays, mailboxes, web mail and all the tricks of the trade that can be used to compromise email systems. We walk you through the process of hacking into e-mail servers.

Chapter 7: The World Wide Web of Vulnerabilities It could be argued that the World Wide Web, invented by Tim Berners Lee in 1990, is now fundamental to our existence. You will learn how it is based on aging protocols and how to hack the infrastructure that supports your favorite websites and web applications.

Chapter 8: Virtual Private Networks VPNs are an increasingly popular solution for both personal and corporate use, with countless employees logging into their company's internal network remotely using this technology. We'll pick apart some of the ways in which common VPNs work and, of course, how to approach them like a hacker.

Chapter 9: Files and File Sharing Up to this point, you will have looked at a typical organization from an external perspective. Now it's time to step inside the internal perimeter and see what resides on the internal network, starting with file servers. In this chapter, we'll cover the theory necessary to get a better handle on the Linux file system and how to use files and file sharing technology to get a foothold in systems.

Chapter 10: UNIX Switching from Linux, which up to this point has been our focus, in this chapter we take a look at a UNIX operating system. We'll show you some of the quirks of these operating systems, including vulnerabilities for you to explore and exploit.

Chapter 11: Databases In this chapter, we start by showing you how to perform basic database administration, using the Structured Query Language (SQL), before demonstrating attacks that utilize this and other features of databases. This chapter serves as a crucial basis for understanding how high-profile data leaks actually work and how to exploit them, which we will continue to explain in the subsequent chapter.

Chapter 12: Web Applications Web applications are a huge part of everyday business for almost every organization—and they're also a huge target. We cover the essentials of web applications in this chapter, focusing on the most dangerous types of attacks that continue to plague small and huge companies across the globe. You'll find that everything you've learned so far really comes together in this introduction to web application hacking.

Chapter 13: Microsoft Windows Thus far, you've seen the myriad of flaws in the Linux and UNIX operating systems. Now it's time to shine the spotlight on Microsoft's Windows operating system. The focus is Windows Server, which is the technology powering countless organizations' IT infrastructure. Like Linux, Windows Server can host DNS, email, web, and file sharing services. We'll help you transfer your Linux and UNIX hacking skills over to Windows in this part of the book.

Chapter 14: Passwords Throughout the book, we have referenced passwords and their hashes. In this chapter, you have the chance to understand how passwords are hashed and the inherent problems in many algorithms that people rely on every day for securing their data. We'll give you guidelines on cracking password hashes—that is, recovering plaintext passwords from the data you've accessed in the labs you've been hacking thus far.

Chapter 15: Writing Reports You won't get far as an ethical hacker or penetration tester if you are unable to convey your findings to your client, colleagues, or superiors. Writing a penetration test report utilizes a whole new skill set, and we'll show you what you need to do to communicate effectively using a sample report as a guideline.

Hardware and Software Requirements

To follow along with the exercises in this book, you will need either a laptop or a desktop computer running Windows, macOS, or a mainstream Linux distribution with enough hard drive or solid-state drive space for the software and

tools demonstrated within the chapters. You'll also need enough main memory (RAM) to run VMs and an Internet connection for downloading everything you will need. We cover hardware and software requirements in Chapter 3, "Building Your Hack Box," and walk you through all of the steps required to get hacking. Here are the *minimum* requirements:

- A modern Intel or AMD CPU (with Streaming SIMD Extensions 2 [SSE2], which almost all processors have)
- 4 GB of RAM
- 50–100 GB of hard disk drive (HDD) or solid-state drive (SSD) capacity
- Internet access for downloading software and running certain demonstrations

How to Use This Book

This book was designed to be read through from start to finish, with practical activities in almost every chapter that you can work through as you go. The book can be read without carrying out any of the activities, and it will still make sense. Or perhaps you are the type of reader who likes to read content once first and then go back to try the practical elements? Either way, to get the most out of *Hands on Hacking*, you will want to attempt the practical hacking exercises, and we'll show you exactly how to do this.

Even though most chapters address a particular area of an organization's network infrastructure, skipping to the chapter in which you are most interested may give you a headache. This is because we introduce many concepts early on in the book that you will need to use later and that apply across different areas of hacking. In later chapters, you will find only small reminders to previously introduced tools and techniques, with ways in which you can apply them in a new setting.

To carry out the practical activities, which start in Chapter 3, "Building Your Hack Box," you will need to ensure that you have access to the downloadable content found at www.hackerhousebook.com. You will need to use the username "student" and password "student" to access the `/files` content. (The only purpose of this authentication is to stop search engines from flagging our website as malicious. There's a lot of potentially malicious code in the files that you'll learn how to use responsibly.) This link will allow you to download a single `files.tgz` compressed archive containing a large number of tools. The website also hosts three labs: the mail server and UNIX lab from Hacker House, along with a purpose-built lab created exclusively for this book that contains numerous labs in a single download. The content is mirrored on Wiley's website, at www.wiley.com/go/handsonhacking. The details of setting up your own

computer to carry out the practical activities are covered in Chapter 3, “Building Your Hack Box,” but you should read through Chapter 1 and Chapter 2 first.

The other software and tools that we reference are generally open source, are freely available, and can be downloaded from the relevant developer’s website.

How to Contact the Authors

You can contact the book authors via info@hacker.house. If you spot any errors or omissions or you have any feedback in general, we’d love to hear from you. If you’re interested in our online training, which complements the contents of this book, head to hacker.house/training. Any updates and labs accompanying this book will be posted at www.hackerhousebook.com. You can learn more about Hacker House and our services on our home page hacker.house.